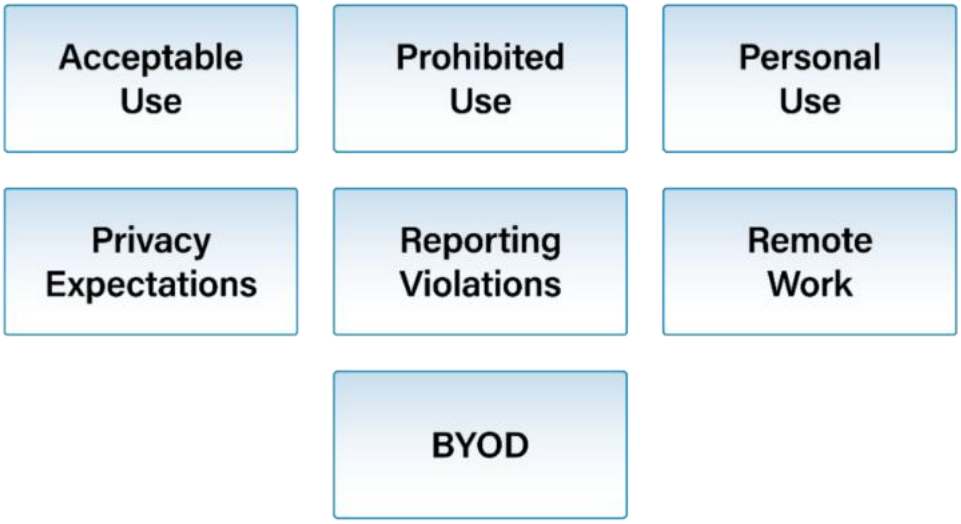
Acceptable Use Policy (AUP)

1. Purpose:

This policy explains how people may use the organization's technology, cloud services, devices, networks, and data in a safe, responsible, and compliant way. It exists to protect donors and beneficiaries' data, prevent phishing, and malware, set clear expectations for technology use, and reduce security risks caused by everyday human behavior like accidental sharing, weak passwords, unsafe links. The AUP follows the structure, intent, and IG1 focus of the CIS Acceptable Use Policy, and it is tailored to a small non-profit with an external IT provider.

2. Scope:

The AUP applies to all individuals who access org systems or data: employees, volunteers, interns, contractors, third-party service providers, and board members. It covers organization-issued devices like laptops, tablets, phones, approved personal devices when allowed (BYOD) cloud systems like Microsoft 365, SharePoint, Salesforce, Docusign, Zoom/Teams, or transmitted on behalf of the organizations.



This figure summarizes the core components of an Acceptable Use Policy, including what users are allowed to do, what they must not do, and how limited personal use is handled. It also highlights expectations for privacy, reporting violations, remote work requirements, and rules for using personal devices

Role	Responsibilities Under This AUP
All Employees	Use organization systems only for authorized business purposes; follow all data-handling rules; store files only in approved systems ; protect login credentials and use MFA; report suspicious emails using Outlook's "Report" feature; secure laptops and mobile devices; comply with all prohibited-use restrictions.
Volunteers & Interns	Follow the same acceptable-use rules as staff; access only the data required for assigned tasks; avoid downloading or saving organizational data to personal devices; report unusual system behavior or suspected phishing immediately.
Program Managers	Ensure their team members understand and comply with this AUP; request access changes when staff join, change roles, or leave; reinforce safe handling of donor/beneficiary information; ensure volunteers and interns receive appropriate guidance and supervision.
Executive Director	Owns policy approval and enforcement; ensures compliance across the organization; collaborates with the external IT service provider to support secure operations; authorizes exceptions to this policy when necessary.
External IT Service Provider	Implements security controls; manages staff onboarding/offboarding from systems; maintains the security of laptops, Wi-Fi, VPN, and cloud administration; monitors and reviews alerts in Microsoft 365 Defender and reports issues to leadership.
Contractors & Third-Party Service Providers	Use organization systems only as authorized; protect sensitive organizational data in accordance with confidentiality agreements; follow all AUP rules applicable to employees when accessing organizational systems.
Board Members	Use organizational email and cloud accounts only for board-related work; safeguard confidential organizational information; follow password and MFA requirements; report any suspicious activity promptly.
Human Resources	Maintain signed AUP acknowledgments for all personnel; ensure AUP is part of onboarding and annual refresh; coordinate with managers and IT provider on access changes during hiring, role changes, or separation.

3. Policy Requirements:

3.1 Authorized and prohibited use

Authorized Use (what "good" looks like):

Users may access organization systems only for legitimate business purposes; store work files only in approved platforms like Microsoft 365, SharePoint, OneDrive business or Salesforce; use staff Wi-Fi for work; and follow least-privilege principles by accessing only the information needed for their role. Users should keep devices updated; lock screens when stepping away and promptly report loss/theft or suspected abuse.

Prohibited Use (what must not happen):

Users must not install unapproved software, disable security features, or connect to unknown USB/IoT devices. Users must not store organizational data in personal email or personal cloud like personal Google drive/Dropbox/iCloud. Users must not share accounts, passwords, or MFA tokens; must not use guest Wi-Fi to reach internal systems; and must not engage in illegal, abusive or harassing behavior using organization systems.

Why this helps:

Clear rules reduce confusion, support consistent decisions, and shrink the attack surface by stopping risky behaviors before they spread, which is the core objective of an AUP in IG1 organization.

3.2 Data protection and Confidentiality

Core requirement:

Treat all donor and beneficiary data as confidential unless explicitly marked otherwise. Store sensitive files only in approved locations like SharePoint/OneDrive business or Salesforce, share externally with intent and time limits, and never email work files to personal accounts. Paper records must be secured; screens must be locked; and conversations handled discretely to reduce "shoulder surfing".

Why this helps:

Centralizing data in managed platforms improves access controls, logging, and retention; it also reduces accidental loss or unauthorized sharing, aligning with IG1's practical emphasis on strong, understandable guardrails.

Low/No-cost helper:

- Microsoft 365 "user reported" & alerting basics – Microsoft 365 tenant already includes the Microsoft Defender portals where admins can see incidents/alerts, set policies, and view reports which can act as a "single view" for potential data or email issues without buying a separate expensive solution.

3.3 Account and Password Security

Core requirement:

Use unique strong passwords for work accounts; store them only in the approved password manager; enable Multi-Factor Authentication (MFA) anywhere available (Microsoft 365, Salesforce, VPN); never share credentials or MFA prompts; and avoid browser "remember my password" features.

Low/No-cost helper:

- KeePassXC (free, open-source, offline), it has public security reviews and avoids vendor lock-in. Use KDBX4 format and a strong master password; store the database in OneDrive for business if you need backup/sync with device encryption enabled.

  KeePassXC User guide: KeePassXC: User Guide

- Bitwarden (free/low-cost), publishes independent security assessments by Cure53. The free tier supports personal vaults; small paid org plans add sharing; it's suitable if the organization wants cloud sync with strong auditing transparency.

Procedure: KeePassXC quick start

→ Install KeePassXC from the official site; create a database using the KBDX4 and a long master passphrase.
→ Add entries for Microsoft 365, Salesforce, Zoom, etc.
→ Save the vault in OneDrive Business so it is backed with org policies
→ Do not store the master passphrase anywhere digital

3.4 Email and Internet Usage

Email:

Use organization email for work and be cautious with links/attachments. If an email is not expected, verify before clicking. Report suspicious messages immediately using the built-in Outlook "Report" button. Microsoft recommends using the native button instead of legacy add-ins; admins can route reported items to the vendor and to a shared mailbox.

Internet:

Avoid unknown or high-risk sites; do not download untrusted software. Let the vendor manage browser protections and safe browsing defaults.

Free/no-cost implementations:

- Outlook "Report" button (built-in) - enable tenant-wide so staff can report phishing with one click; configure User reported settings to send copies to Microsoft and your vendor's mailbox for review. It has been documented in Microsoft Learn; may step-by-step guides exist.

Report Phishing documentation: Report phishing and suspicious emails in Outlook for admins - Microsoft Defender for Office 365 | Microsoft Learn

- Quad9 secure DNS (free) - set DNS to 9.9.9.9 on routers/devices to block known malicious domains (phishing/malware) using threat intel from multiple providers, maintained by a nonprofit.

Short procedure: turn on Outlook "Report"

→ Go to security.microsoft.com - settings – email & collaboration, user reported settings.
→ Choose Use the built-in Report button and select Send to Microsoft and my reporting mailbox; specify the shared mailbox and vendor monitors.

Short procedure: set Quad9 on a Windows laptop

→ Settings – network & internet – Wi-Fi – your network – edit DNS settings – manual
→ IPv4: 9.9.9.9 (preferred) and 149.112.112.112 (alternate) save, test by browsing normally.

Windows Documentation for Quad9: Windows 10 - Quad9 Documentation

Why this helps: CISA/NSA/FBI emphasize user reporting and layered controls to disrupt phishing early; combining user-reported messages with a proactive DNS layer materially reduces risk for small organizations.

3.5 Mobile Device & Remote work rules

Organization issued devices:

Devices must have screen locks; approved security controls must remain enabled; updates should install promptly; and lost/stolen devices must be reported immediately.

BYOD (if authorized)

Personal devices may access work data only with written approval and required controls like screen locks, separate work apps, remote wipe consent if lost/compromised or upon separation. Work data must never be saved to personal apps or personal cloud

Remote work:

Use secure home Wi-Fi (password protected); avoid open public Wi-Fi; use VPN if required; work in private/semi-private spaces to prevent unintended viewing.

3.6 Monitoring & Incident Reporting

Monitoring:

Users understand the organization may monitor and log activity on managed systems for security and compliance; there is no expectation of personal privacy on organization systems.

How to report quickly: If you suspect phishing, lost device, strange MFA prompts, or exposed data

1. Use the Outlook "Report" button or forward to security person
2. Call vendor persons if urgent

3. Tell your manager if donors/beneficiaries might be affected.

Where the vendor reviews alerts:

Your vendor can review incidents, alerts, and reports in the Microsoft Defender portal and send weekly summaries to the leadership. This provides a single, low-cost dashboard suitable for small nonprofits.

Compliance & Enforcement

Enforcement:

Violations may result in retraining, access changes, discipline up to termination, contract actions for third parties, and legal remedies if applicable. The ED with vendor ensures fair and consistent enforcement.

Acknowledgement:

All users must sign the AUP on hire and re-acknowledge annualy, HR retains signed copies.

Exceptions, Enforcement, Revision history

Exceptions:

Unusual needs require written exception requests stating business need, duration, risks, and compensating controls; must be approved by the executive director and expire within 12 months unless renewed.

Risk Linkage Table

Risk #	Risk Title	AUP Section(s) that treat this risk
4.5.1	Inadequate controls over unauthorized and personal device usage	3.1 Authorized and prohibited use
4.1.3	Lack of Shared Drive Security Policy	3.2 Data Protection and Confidentiality
4.3.1	Lack of Password Policy	3.3 Account and Password Security
4.1.4	Lack of Comprehensive Workforce Security Training	3.4 Email and Internet Usage
4.4.3	Remote Access VPN Hardening	3.5 Mobile Device & Remote work rules
4.5.5	Vendor-Managed anti-malware without internal verification	4. Monitoring and Incident Reporting
4.1.1	Lack of Oversight and Communication with Third-Party IT Provider	5. Compliance & Enforcement
4.2.5	Recovery Process Governance and Testing Gaps	6. Exceptions, Enforcement

Revision history:

Version	Date	Summary of Changes	Author
1.0	[03/19/2026]	Initial release	Priyadharshini Rengaramanujam

References:

This Acceptable Use Policy was developed using the following authoritative industry sources to ensure alignment with recognized security best practices and the CIS Implementation Group 1 (IG1) safeguards:

1. **CIS Acceptable Use Policy Template** – Used as the structural foundation for this policy, including Purpose, Scope, Applicability, User Responsibilities, Prohibited Use, Privacy Expectations, Remote Work, and BYOD guidance.

   URL: https://www.cisecurity.org/insights/white-papers/acceptable-use-policy-template-for-the-cis-controls

2. **CIS Critical Security Controls v8.1** – Used to align this policy with IG1 safeguards for Access Control, Password & Account Management, Data Protection, Secure Configuration, Monitoring, and Service Provider Management.

   URL: https://www.cisecurity.org/controls/cis-controls-list

3. **Microsoft Learn Documentation** – Used to inform the phishing reporting procedure and low-cost email-security recommendations.

   URL: https://learn.microsoft.com/en-us/defender-office-365/submissions-outlook-report-messages

4. **Quad9 (Global Cyber Alliance)** – Used to support the DNS-security recommendation for phishing and malware defense.

   URL: https://globalcyberalliance.org/work/quad9/

5. **KeePassXC Security Audit & Documentation** – Used to justify KeePassXC as a validated free password-manager option.

   URL: https://keepassxc.org/audits/